

Abuse of Stolen Session Tokens in SaaS Platforms

response

Identity / SaaS · **Critical** severity · SOC IR Playbook

Incident type	Account Hijack - Session Token Abuse
Severity	Critical
Priority	Critical
Detection sources	CASB, SIEM, EDR, SaaS Audit Logs, User Reports, Threat Intelligence Feeds

Scenario

An attacker gains access to a valid session token (e.g., via XSS, phishing, malware or token theft from endpoints) and uses it to impersonate a legitimate user on a SaaS platform (e.g., Microsoft 365, Google Workspace, Salesforce, Slack). This allows access without triggering MFA or login anomaly alerts.

MITRE ATT&CK

T1078, T1185, T1539

Preparation

Enable session management logs In all SaaS platforms to capture token reuse or suspicious IP logins Deploy CASB and SaaS Security tools To monitor user behaviour, token anomalies and session reuse Use Conditional Access policies Based on geolocation, device trust and user risk scores Educate users on phishing and token theft Including how session tokens can be abused Integrate endpoint protection To prevent token theft via malware

Detection & Analysis

Alert triggered Unusual session activity (e.g., login from known IP but unusual behaviour or location) Check for duplicate sessions Same token reused from different IPs or geolocations Review recent user activity Look for data downloads, permission changes, new app integrations Analyse endpoint logs Identify malware or tools (e.g., RedLine, Vidar) that may have extracted tokens

Containment

Revoke all active sessions Force logout for the affected user across all devices and apps Disable user account temporarily If attacker activity is ongoing or damage is high Block attacker IPs or devices At the SaaS provider, CASB or firewall level Notify user and support team Inform user to reset passwords and validate MFA devices

Eradication

Scan endpoint for malware Ensure no token stealer is still active on the user's device Rotate any exposed credentials or tokens For linked applications or integrations Review session storage practices Ensure session tokens are not stored in plaintext or improperly cached Strengthen SaaS login policies Enforce re-authentication for sensitive actions or high-risk logins

Recovery

Re-enable user access with strict monitoring After ensuring the endpoint is clean and MFA is re-enforced Monitor user activity closely Apply alerts on behavioural deviation or abnormal downloads Educate user on signs of session hijacking Reinforce best practices for session security Conduct internal checks To ensure no lateral movement or privilege abuse occurred

Lessons Learned & Reporting

Complete RCA Determine how token was stolen: malware, phishing, browser sync, etc. Improve session hygiene policies Reduce session duration, prevent reuse across devices or geos Train employees Regularly on SaaS risks and session awareness Document findings In IR logs and lessons learned report Notify third parties or regulators If

sensitive data was accessed or shared externally

Tools typically involved

CASB (e.g., Microsoft Defender for Cloud Apps, Netskope, Lookout); SaaS Security Posture Management (e.g., Obsidian, AppOmni); SIEM (e.g., Sentinel, Splunk); Endpoint Detection and Response (e.g., CrowdStrike, Cortex XDR); Identity Providers (e.g., Okta, Azure AD, Google Workspace); Browser Security Tools (e.g., LayerX, Seraphic)

Success metrics (SLA targets)

Session Revocation Time <10 minutes from detection Endpoint Validation Time <1 hour Post-incident MFA Reinforcement 100% completion within 24 hours SaaS Behaviour Monitoring Duration ? 14 days post-incident RCA and Reporting Completion Within 3 business days